Liquid Bullet

Cuentas de Liquid Bullet

Plan técnico completo del inicio de sesión: solo Cloudflare, códigos enviados desde un correo creado por ti, base de datos optimizada y una interfaz con la esencia de la app.

100 % Cloudflare | Correo propio (Gmail dedicado) | Costo 0 | Opcional y local-first | Passkeys

Versión
1.0 · noviembre 2026

Estado
Propuesta: aún no implementado

Alcance
Correo + contraseña, código, recuperación, sincronización

Excluido
Inicio por teléfono (cancelado)

Índice

1 Resumen y decisiones
2 Principios
3 Arquitectura en Cloudflare
4 Protocolo del correo propio
5 Base de datos D1 optimizada
6 Datos de música en R2 optimizados
7 Contraseñas, códigos y sesiones
8 API del Worker
9 Sincronización entre dispositivos
10 Interfaz con la esencia de Liquid
11 Pantallas una por una
12 Textos, errores y estados
13 Correos que envía la app
14 Amenazas y defensas
15 Límites y costos
16 Fases y criterios de aceptación
17 Lo que necesito de ti
A Anexo: esquema SQL completo
B Anexo: configuración del Worker
C Anexo: formato de los datos

1 Resumen y decisiones

Liquid Bullet hoy guarda todo en el navegador de cada persona. Este plan añade cuentas **opcionales** para no perder nada y tener lo mismo en todos los dispositivos, sin salir de Cloudflare y sin pagar.

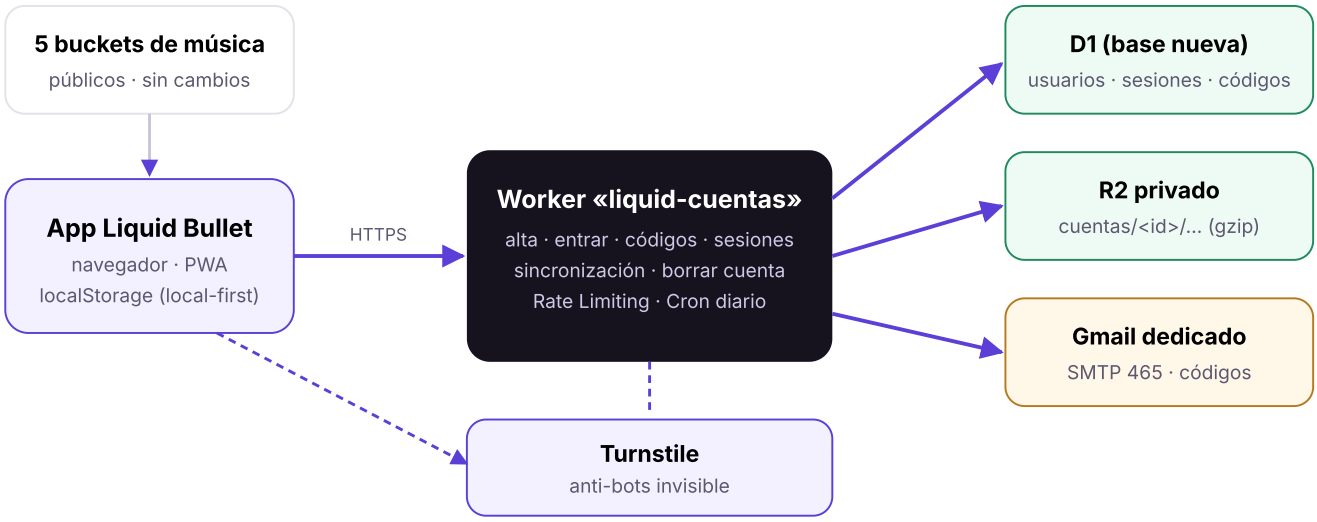
DECISIÓN	ELEGIDO	POR QUÉ
Proveedor	**Solo Cloudflare**: Worker, D1, R2, Turnstile, Rate Limiting, Cron	Liquid ya vive en Cloudflare (los 5 buckets de música).
Forma de entrar	**Correo + contraseña**, con **código de 6 dígitos** para confirmar y recuperar. Passkeys (huella o Face ID) como extra.	El teléfono quedó cancelado: los SMS cuestan.
Envío de correos	**Gmail dedicado creado por ti**, enviado por el Worker por SMTP con contraseña de aplicación	Gratis, sin dominio, ~500 al día. **Puede llegar a Spam** (se avisa en la app).
Cuentas	**D1**: la base nueva que me darás	Consultas por correo e índices; ~1 KB por usuario.
Datos de música	**R2 privado**: un archivo por persona, comprimido	Lo pesado (escucha, playlists) fuera de D1: más barato y rápido.
Modelo	**Local-first**: el navegador sigue siendo la fuente inmediata y la cuenta sincroniza	La app sigue igual de rápida y funciona sin conexión.
Costo	**0 USD** en planes gratuitos	Ver sección 15.

~1 KB	8×	0 USD
por usuario en D1	menos peso en R2 con ids cortos y gzip	con Gmail dedicado y planes gratis

2 Principios

1. **Opcional siempre.** Sin cuenta, Liquid funciona exactamente como hoy. La cuenta se ofrece, nunca se exige.
2. **Local-first.** El navegador guarda y responde al instante. La nube solo sincroniza cambios en segundo plano.
3. **Nada se pierde.** Al unir dispositivos, se mezcla. Lo borrado deja una marca para no «resucitar».
4. **Privacidad real.** Sin anuncios, sin analítica, sin vender datos. La contraseña nunca viaja en claro ni se guarda en claro.
5. **Mínimo en la base, lo pesado en archivos.** D1 solo para la cuenta; la música personal, en R2 comprimida.
6. **Cero costo.** Todo diseñado para los planes gratuitos y con margen.
7. **Esencia Liquid.** La cuenta es parte de la app: sus temas, su escena surrealista, sus portadas e iconos y su lenguaje. No es un formulario genérico.
8. **Honestidad.** La app avisa que los correos pueden llegar a Spam y explica cada estado (sin conexión, sincronizando, sesión caducada).

3 Arquitectura en Cloudflare



- **Worker** `liquid-cuentas` (en `*.workers.dev`, gratis): la única puerta. Valida, cifra, envía correos y lee o escribe en D1 y R2.
- **D1**: la base nueva dedicada al inicio de sesión. Solo datos de cuenta; ocupa muy poco.
- **R2 privado** (un bucket nuevo, sin URL pública y separado de los 5 de música): los datos de música de cada persona.
- **Turnstile**: comprobación anti-bots invisible al crear cuenta, entrar y recuperar.

- **Rate Limiting** (binding de Workers): frena intentos repetidos por IP y por correo sin gastar escrituras de D1.
- **Cron Trigger** diario: borra códigos caducados, sesiones vencidas y actividad de más de 90 días, y ejecuta los borrados de cuenta programados.
- **Los 5 buckets de música** no cambian.

Opcional más adelante: todo en el mismo sitio

Mover la web a **Cloudflare Pages** (gratis, `liquidbullet.pages.dev`) con **Pages Functions** en `/api`. La app y la API quedarían en el mismo origen, y la sesión podría ir en una cookie `HttpOnly; Secure; SameSite=Strict`, que ningún script puede leer. Es la opción más segura y no necesita dominio. Contra: cambia la dirección de la web, así que habría que redirigir la de GitHub Pages.

4 Protocolo del correo propio

Los códigos salen de una cuenta de Gmail creada por ti solo para Liquid Bullet. El Worker los envía por el servidor SMTP de Gmail. Todo lo demás sigue en Cloudflare.

4.1 Preparación (la haces tú, una vez)

1. Crear una cuenta de Gmail **nueva y dedicada**, por ejemplo `liquidbullet.app@gmail.com`. No uses tu correo personal.
2. Nombre visible de la cuenta: **Liquid Bullet**. Foto de perfil: el logo de la app, que se ve en Gmail junto al correo.
3. Activar la **verificación en dos pasos** (obligatoria para el paso 4).
4. Crear una **contraseña de aplicación** (Cuenta de Google → Seguridad → Contraseñas de aplicaciones), con el nombre «Worker Liquid».
5. Pasarme esa contraseña **por un canal privado**. Se guarda como secreto del Worker (`wrangler secret put SMTP_PASS`) y nunca va en el repositorio ni en la web.

4.2 Cómo envía el Worker

PARÁMETRO	VALOR
Servidor	`smtp.gmail.com`, puerto **465** (TLS directo) mediante `connect()` de `cloudflare:sockets`. Workers bloquea solo el puerto 25.
Autenticación	AUTH LOGIN con el correo y la contraseña de aplicación (secretos `SMTP_USER` y `SMTP_PASS`)
Remitente	`"Liquid Bullet" <liquidbullet.app@gmail.com>`
Formato	MIME `multipart/alternative`: versión de texto + HTML ligero (mejor entrega y menos Spam)
Asunto	**Siempre con el código**: «Tu código de Liquid Bullet: 482917». Se ve sin abrir el correo y se busca fácil.
Reintentos	2 reintentos con espera (1 s y 4 s). Si fallan, la app ofrece «Reenviar» y lo deja anotado en el registro.
Respuesta	El Worker responde en cuanto el código queda guardado y envía el correo con `ctx.waitUntil()`: la app no espera al SMTP.

4.3 Límites y cómo protegerlos

- Gmail permite alrededor de **500 envíos al día** (límite de Google; puede variar). Solo se envían códigos al crear cuenta, recuperar contraseña, cambiar correo, borrar cuenta y en avisos de seguridad.
- **Topes propios**, más bajos que los de Google:
  - 1 código por minuto, 5 por hora y 10 por día por correo.
  - 20 por hora por IP.
  - 400 por día en total; de ahí en adelante solo se mandan los códigos más urgentes.
- **Turnstile** obligatorio antes de cualquier envío.
- Si Google pausa la cuenta por exceso, el Worker lo detecta (error 5xx de SMTP) y la app muestra «Estamos teniendo problemas para enviar correos, prueba en unas horas». Mientras tanto, las passkeys siguen funcionando.

⚠ Puede llegar a Spam: así se avisa

- Pantalla del código: «Te enviamos un código a l•••@gmail.com. **Puede tardar un minuto y llegar a Spam o Promociones**: búscalo como *Liquid Bullet*».
- A los 30 s sin escribir el código: «¿No lo ves? Revisa **Spam** y márcalo como *No es spam*: los próximos llegarán bien».
- Botón **Abrir correo**: abre Gmail, Outlook o iCloud según el correo.
- Ajustes → Ayuda: «Añade *liquidbullet.app@gmail.com* a tus contactos para que siempre lleguen».

Plan B sin tocar nada más

Si algún día hace falta más volumen o mejor entrega, se cambia solo el «remitente» por Cloudflare Email Service con un dominio propio. El código del Worker lo trata como un módulo intercambiable (`enviarCorreo()`).

5 Base de datos D1 optimizada

D1 guarda solo lo imprescindible de la cuenta. Cada consulta va por índice y cada escritura se justifica. Así la base cabe holgada en el plan gratuito durante años.

5.1 Tablas

TABLA	CONTENIDO	TAMAÑO APROX.
`usuarios`	id, correo normalizado (único), confirmado, hash y sal de la contraseña, nombre, avatar, tema preferido, fechas, borrado programado	~300 bytes/usuario
`sesiones`	id, usuario, hash del token de renovación, familia (para detectar robo), dispositivo, creada, última vez, caduca	~200 bytes por dispositivo
`codigos`	correo, motivo, hash del código, intentos, caduca	Temporal (se borra)
`passkeys`	id de credencial, usuario, clave pública, contador, nombre, fechas	~350 bytes por passkey
`actividad`	usuario, tipo, fecha, dispositivo (90 días)	~60 bytes por evento

5.2 Optimizaciones concretas

TÉCNICA	EFECTO
Tablas `STRICT` y tipos mínimos	Sin datos mal tipados. Las fechas como `INTEGER` (segundos Unix): 8 bytes en vez de 24 de texto.
Hashes como `BLOB` (32 bytes)	La mitad de espacio que en hexadecimal (64 caracteres).
Ids aleatorios de 16 bytes en `BLOB`	No revelan cuántos usuarios hay y ocupan menos que un UUID en texto (36).

Correo normalizado + índice único (`lower(trim())`)	Entrar y crear cuenta leen **1 fila**, nunca la tabla entera.
Índices compuestos (`sesiones(usuario, caduca)`, `codigos(correo, motivo)`)	Listar dispositivos o validar un código: lecturas mínimas.
`WITHOUT ROWID` en `codigos` y `passkeys`	La clave primaria es el propio índice: menos espacio y una búsqueda menos.
`db.batch()`	Varias sentencias en un solo viaje y de forma atómica (p. ej. crear usuario + sesión + actividad).
Sentencias preparadas siempre (`.bind()`)	Sin inyección SQL y con planes de consulta reutilizados.
«Última vez» como mucho 1 vez por hora	Renovar el pase no escribe en cada petición: hasta 95 % menos escrituras en `sesiones`.
Contadores de intentos fuera de D1 (binding de Rate Limiting)	Los frenos anti-abuso no gastan escrituras de D1.
Limpieza diaria con Cron	Códigos caducados, sesiones vencidas y actividad antigua: la base no crece sola.
Nada de datos de música en D1	Lo pesado va en R2: D1 se queda en ~1 KB por usuario.
`PRAGMA optimize` en el Cron	Estadísticas de índices al día para que SQLite elija bien.

5.3 Lecturas y escrituras por acción

ACCIÓN	FILAS LEÍDAS	FILAS ESCRITAS
Crear cuenta (pedir código)	1 (¿existe el correo?)	1 (código)
Confirmar código y crear usuario	1–2	3 (usuario, sesión, actividad) + borrar el código
Entrar	1	2 (sesión, actividad)
Renovar el pase (cada 15 min con la app abierta)	1	1 (rotación) · «última vez» como mucho cada hora
Sincronizar datos	0 en D1 (el pase se valida por firma)	0 en D1 · 1 escritura en R2

Capacidad. Con ~1 KB por usuario, 1.000 usuarios ocupan ~1 MB de D1, y 100.000 usuarios, ~100 MB. Muy por debajo del máximo de una base gratuita.

6 Datos de música en R2 optimizados

6.1 Estructura

```
# Bucket privado: liquid-cuentas
cuentas/<id-usuario>/datos.json.gz        # favoritas, playlists, follows, ajustes, saltos, última escucha
cuentas/<id-usuario>/escucha-2026.json.gz  # registro por día del año (Stats y algoritmo)
cuentas/<id-usuario>/escucha-2025.json.gz  # años anteriores: se leen solo si los pides
```

6.2 Cuatro optimizaciones que suman

TÉCNICA	DETALLE	AHORRO
Ids cortos de canción	Hoy cada id mide **59 caracteres** de media (p. ej. `brush3:101-200-148-clairo-4ever-mp3-c0bf5f`). Se usa la letra del bucket + el sufijo de 6 hex que ya traen: `b·c0bf5f`, **7 caracteres**. Comprobado: **0 colisiones** en las 3.931 canciones; `build_catalog.py` lo verificará en cada build.	~8× en ids
Gzip	El navegador comprime con `CompressionStream('gzip')` antes de subir; el Worker lo guarda tal cual.	4–6× extra
Un archivo por año de escucha	Lo que cambia a diario (la escucha) se separa de lo que cambia poco. Sincronizar sube solo lo que cambió.	Menos bytes por subida
Escrituras condicionales	`put()` con `onlyIf: { etagMatches }`: si otro dispositivo escribió antes, se rechaza y la app mezcla y reintenta. Sin bloqueos ni pérdidas.	0 conflictos perdidos

6.3 Peso por persona

PERFIL	HOY EN EL NAVEGADOR	EN R2 (IDS CORTOS + GZIP)
Casual (pocas favoritas, 2–3 playlists)	20–100 KB	**3–15 KB**
Normal (uso diario, meses)	200–500 KB	**25–70 KB**
Intenso (más de un año diario, playlists grandes)	1–1,5 MB	**120–200 KB**

1.000 usuarios intensos ocuparían unos **200 MB** de los 10 GB gratuitos de R2.

6.4 Qué NO se sube

- Caché de letras, caché de la biblioteca, descargas offline y fondos: se regeneran o son del dispositivo.
- Cola de reproducción y segundo exacto: son de cada dispositivo. Como opción futura, «Continuar en este dispositivo».

7 Contraseñas, códigos y sesiones

7.1 Contraseñas: estiramiento en dos fases

En el plan gratuito, cada petición de un Worker tiene un tiempo de CPU muy corto, y un PBKDF2 fuerte no cabe entero ahí. Por eso el trabajo pesado lo hace el dispositivo y el Worker añade un secreto que solo él conoce:

```
// 1) En el navegador (WebCrypto)
salCliente = SHA-256("liquidbullet:v1:" + correoNormalizado)        // determinista: no revela si el correo existe
claveCliente = PBKDF2-SHA256(contraseña, salCliente, 600.000 iteraciones, 32 bytes)
// 2) En el Worker (WebCrypto)
salServidor = 16 bytes aleatorios por usuario (en D1)
guardado = PBKDF2-SHA256( HMAC-SHA256(PIMIENTA, claveCliente), salServidor, 10.000 iteraciones )
// Comparación en tiempo constante; PIMIENTA = secreto del Worker, nunca en D1
```

- **La contraseña nunca sale del dispositivo.** Solo viaja `claveCliente`, siempre por HTTPS.
- **Si alguien robara la base**, no podría hacer nada sin la pimienta. Y aun con ella, cada intento costaría 600.000 iteraciones.
- **Mínimo 10 caracteres.** Medidor de fuerza en la interfaz.
- **Contraseñas filtradas:** se comprueban de forma anónima contra *Have I Been Pwned* (rango k-anonimato: solo se envían 5 caracteres del hash). Si salió en una filtración, se pide otra.
- **Versión del esquema** (`v1`) guardada, para subir iteraciones en el futuro sin romper cuentas.

7.2 Códigos de 6 dígitos

- Se generan con `crypto.getRandomValues` (sin sesgo: rechazo de valores fuera de rango).
- Se guarda solo `HMAC(PIMIENTA, código + correo + motivo)`.
- Caducan a los **10 min**, permiten **5 intentos** y son de un solo uso. Uno nuevo invalida el anterior.
- Motivos separados: `alta`, `recuperar`, `cambiar-correo`, `borrar`. Un código de alta no sirve para recuperar.

7.3 Sesiones

PIEZA	DISEÑO
Pase de acceso	Token firmado con HMAC-SHA256 (secreto `FIRMA`), válido **15 min**, con `usuario`, `sesión` y `caduca`. Se valida sin leer D1.
Token de renovación	32 bytes aleatorios, válido **60 días** y renovado en cada uso (rotación). En D1 solo se guarda su SHA-256.
Detección de robo	Si llega un token de renovación ya usado, se revoca toda su **familia** (todas las sesiones de ese inicio) y se avisa por correo.
Dónde se guarda	Con la web en GitHub Pages: IndexedDB del navegador, protegida por la CSP estricta que ya tiene la app. Con la opción Pages (sección 3): cookie `HttpOnly`.
Cerrar sesión	Revoca la sesión en D1 y borra los tokens del dispositivo. «Cerrar en todos» revoca todas menos la actual.
Cambio de contraseña	Cierra todas las demás sesiones automáticamente.

7.4 Passkeys (huella o Face ID)

WebAuthn con verificación en el Worker (biblioteca SimpleWebAuthn, compatible con Workers). Se ofrece después de crear la cuenta: «¿Entrar la próxima vez con tu huella?». No necesita correo ni contraseña para entrar, y no se puede robar con un correo falso.

8 API del Worker

Todas las respuestas en JSON. Errores con un código estable (`error: "codigo_incorrecto"`) que la app traduce a los textos de la sección 12.

RUTA	PASE	QUÉ HACE	FRENOS
`POST /alta`	—	Correo + claveCliente + nombre + Turnstile → envía el código. Si el correo ya existe, responde igual y manda un aviso a ese correo.	Turnstile · 5/h por correo
`POST /alta/confirmar`	—	Correo + código → crea el usuario y la sesión.	5 intentos
`POST /codigo/reenviar`	—	Reenvía el código del motivo indicado.	1/min
`POST /entrar`	—	Correo + claveCliente + Turnstile → sesión.	5 fallos → espera
`POST /renovar`	Token	Rota el token de renovación y da un pase nuevo.	—
`POST /salir` · `/salir/todo`	Sí	Cierra esta sesión o todas las demás.	—
`POST /recuperar`	—	Correo + Turnstile → código (respuesta idéntica exista o no).	Turnstile · 5/h
`POST /recuperar/nueva`	—	Correo + código + claveCliente nueva → cambia la contraseña, cierra el resto y entra.	5 intentos
`GET /yo` · `PATCH /yo`	Sí	Perfil: nombre, avatar, tema.	—
`POST /yo/contrasena`	Sí	Actual + nueva.	5 fallos
`POST /yo/correo` (+ `/confirmar`)	Sí	Cambia el correo con código al nuevo y aviso al viejo.	Turnstile
`GET /yo/dispositivos` · `DELETE /yo/dispositivos/:id`	Sí	Lista y cierra sesiones.	—
`GET /yo/actividad`	Sí	Últimos 20 eventos.	—
`/yo/passkeys/*`	Sí / —	Registrar, listar, quitar y entrar con passkey.	Turnstile al entrar
`GET /datos` · `PUT /datos`	Sí	Leer o guardar `datos.json.gz` con ETag (`If-Match`). 412 si cambió → mezclar y reintentar.	≤ 2 MB · 60/h

`GET/PUT /datos/escucha/:año`	Sí	Archivos de escucha por año.	≤ 2 MB
`GET /datos/exportar`	Sí	Todo en un JSON legible.	5/día
`POST /yo/borrar` (+ `/cancelar`)	Sí	Programa el borrado a 7 días (contraseña o passkey + código).	—

Cabeceras: CORS solo para `https://lukoffmon.github.io` (y la dirección de Pages si se muda), `Cache-Control: no-store`, `X-Content-Type-Options: nosniff`. La app suma la dirección del Worker a `connect-src` y `challenges.cloudflare.com` a `script-src` y `frame-src` de su CSP (para Turnstile).

9 Sincronización entre dispositivos

9.1 Cuándo sincroniza

- Al abrir la app y al volver a ella (si pasaron más de 2 min).
- Al pausar, al cerrar o al esconder la app, si hubo cambios.
- Con la app abierta, cada 5 min como mucho y solo con cambios: ~10–30 escrituras al día por usuario.
- Al tocar «Sincronizar ahora».
- Sin conexión, los cambios esperan en cola y suben al volver.

9.2 Reglas de mezcla

DATO	REGLA
Favoritas	Conjunto con fecha por elemento: gana la acción más reciente (añadir o quitar).
Playlists propias	Por id: gana la versión con `actualizado` más reciente. Las borradas dejan marca 90 días.
Canciones de una playlist	Si dos dispositivos editaron la misma playlist, se unen las canciones nuevas de ambos sin duplicar y se conserva el orden de la más reciente.
Escucha por día	Por día y canción: el **máximo** de segundos de cada dispositivo, y se suman entre dispositivos distintos (cada uno lleva su propia cuenta).
Reproducciones totales	Contador por dispositivo; el total es la suma.
Saltos y última escucha	Máximo por canción.
Artistas seguidos, fijadas, ocultas	Como favoritas (conjunto con fecha).
Ajustes (tema, fondo, DJ…)	Por ajuste: gana el último cambio. «Modo ultraligero» y ecualizador quedan como **de cada dispositivo**.

9.3 Conflictos

1) La app lee con su ETag. 2) Mezcla en local. 3) Sube con `If-Match`. 4) Si recibe 412 (otro dispositivo escribió), vuelve al paso 1, con hasta 3 intentos y esperas crecientes. El usuario no ve nada salvo el estado «Sincronizando…».

9.4 Primera vez en un dispositivo

Si el dispositivo ya tenía datos sin cuenta, se muestra la pantalla «Unir» (sección 11, F). Por defecto se une todo, porque así nunca se pierde nada.

10 Interfaz con la esencia de Liquid

La cuenta no es una pantalla aparte: es Liquid. Respira con sus temas, su escena surrealista, sus portadas e iconos, y antes de pedir nada enseña de qué va la app.

10.1 Elementos únicos de la app dentro de la cuenta

ELEMENTO	CÓMO APARECE
Collage de portadas	La bienvenida muestra tres portadas: tus playlists más escuchadas o, si eres nuevo, tres al azar del catálogo. Flotan con el mismo rebote que la app.
Reloj derretido (tema Surrealista)	En la pantalla del código, el reloj de la escena marca los 10 min de validez: sus agujas se derriten mientras corre el tiempo.
Ojos que te siguen	En «Entrar», los ojos de la escena siguen el cursor y **se cierran** cuando escribes la contraseña. Al mostrarla con 👁, se abren.
Código en gotas de cromo	Las 6 casillas son gotas metálicas que se llenan al escribir. Al acertar, se funden en una sola gota con ✓.
Medidor líquido	La fuerza de la contraseña es un tubo que se llena de metal líquido. Su color sigue al tema: cromo, naranja Yem, oro Ébano o grafito Minimalista.
Avatar de la colección	Elige entre tu inicial, los emojis de las playlists propias, los **16 iconos de fondo surrealistas** o los **44 iconos de canción**.
Tu ADN musical	Tras entrar, una tarjeta con tus estilos (los del Lab) y el texto: «Esto viaja contigo a cualquier dispositivo».
Primera canción como miembro	El final del alta propone una canción de tu *Selección rápida* con su radio: «Celébralo con esta».
Saludo en Inicio	«Buenas noches, Luka». Tu nombre aparece en el saludo y en el resumen de tu semana.
Fondo de pantalla	Las hojas de la cuenta usan el vidrio líquido sobre tu fondo actual. En ultraligero, color plano.

10.2 «Conoce Liquid» antes de entrar (enlaces de la review)

En la bienvenida, antes de los botones, va una fila deslizable de tarjetas que abren la review en la sección justa:

TARJETA	ENLACE
⭐ Nuestra nota (9,1/10)	review.html#nota
🧰 Todo lo que trae	review.html#que-trae
🧠 Cómo aprende de ti	review.html#algoritmo
🎨 Sus cuatro temas	review.html#temas
💿 Playlists de autor	review.html#playlists

⚖️ Frente a otras apps	review.html#comparativa
❓ Preguntas	review.html#preguntas

Se abren en una pestaña nueva y la hoja de la cuenta queda donde estaba. La review gana un botón fijo **«Crear mi cuenta»**, que vuelve a la app con la hoja de alta abierta (`./?cuenta=alta`).

10.3 Dónde vive la cuenta en la app

- **Barra superior:** botón redondo junto a Ajustes. Sin sesión, una silueta con un punto que late. Con sesión, tu avatar con un anillo de estado: verde al día, girando mientras sincroniza, gris sin conexión, ámbar si la sesión caducó.
- **Ajustes → Tu cuenta**: primer grupo.
- **Inicio**: una tarjeta discreta para quien usa la app sin cuenta desde hace días («Llevas 3 semanas en Liquid: guarda tu música»). Se cierra con ✕ y no vuelve en 30 días.
- **Momentos clave**: al crear tu tercera playlist o llegar a 20 favoritas, un aviso breve: «¿Lo guardamos en tu cuenta?».
- **Tutorial**: un paso final, «Crea una cuenta para no perder nada (opcional)».
- **Enlace directo** `?cuenta=entrar` / `?cuenta=alta` para la review, los correos y la tienda.

11 Pantallas una por una

Todas en una hoja que sube con el rebote de la app y se cierra deslizando hacia abajo o con Atrás. Respetan los 4 temas, el tamaño de letra, «menos movimiento» y el modo ultraligero.

A **Bienvenida (sin sesión)**

- Collage de 3 portadas · título **«Tu música, en todos tus dispositivos»**.
- Fila «Conoce Liquid» con las 7 tarjetas de la review.
- Tres ventajas: ☁️ no pierdes nada · 📱 lo mismo en todos lados · ✨ tus mixes siguen aprendiendo.
- Botones: **Crear cuenta** · **Entrar** · **Entrar con huella / Face ID** (solo si hay passkey en ese dispositivo) · *Seguir sin cuenta*.
- Pie: 🔒 «Sin anuncios. Tus datos no se venden ni se comparten» · Privacidad.

> Esencia: la escena surrealista detrás; en Yem, chispas verdes; en Ébano, marco dorado.

B **Crear cuenta (3 pasos con barra de progreso)**

1. **Correo**: teclado de correo y sugerencia de erratas («¿Quisiste decir gmail.com?»). Botón Siguiente.
2. **Contraseña**: 👁, medidor líquido, requisitos que se marcan ✓ (10+ caracteres, letras y números, no filtrada) y «Sugerir una segura» (gestor del navegador).
3. **Cómo te llamamos** (opcional) + **avatar** + casilla de privacidad → **Crear y enviar código**.

> Esencia: el avatar se elige entre los iconos de la colección; el botón final es la píldora cromada de la app.

C Confirmar correo

- «Te enviamos un código a **l•••@gmail.com**. **Puede llegar a Spam o Promociones**».
- 6 gotas: saltan solas, aceptan pegar el código entero y en el móvil el teclado ofrece el código (`autocomplete="one-time-code"`). Al completarse se comprueba solo.
- Acierto: las gotas se funden ✓ y vibración corta. Error: tiemblan y dicen «Código incorrecto · te quedan 3 intentos».
- **Abrir correo** · **Reenviar** (anillo de 60 s) · **Cambiar correo** · aviso de Spam a los 30 s.
- Si cierras la app, al volver te espera aquí durante los 10 min.

> Esencia: el reloj derretido cuenta los 10 minutos.

D Entrar

- Correo (recuerda el último) · contraseña con 👁 · compatible con gestores (`autocomplete="username"` y `"current-password"`).
- Passkey arriba de todo, si existe. «¿Olvidaste tu contraseña?».
- Errores sin pistas: «Correo o contraseña incorrectos». Tras 5 fallos, espera de 5 min con cuenta atrás.
- Correo sin confirmar → va a C con código nuevo.

> Esencia: los ojos se cierran mientras escribes la contraseña.

E Recuperar contraseña (3 pasos)

1. Correo → «Si hay una cuenta, te enviamos un código (revisa Spam)».
2. Código en gotas, igual que C.
3. Nueva contraseña con medidor; no puede repetir la anterior → ✓ «Cambiada. Cerramos tus otras sesiones». Entras directo y llega un correo de aviso.

F Unir datos (primera vez en un dispositivo)

- «En este teléfono tienes ❤️ 23 favoritas · 🎵 4 playlists · 📊 2 meses de escucha».
- **Unir con mi cuenta** (recomendado) · *Usar solo lo de la cuenta*.
- Progreso líquido: «Subiendo tus playlists…» → «✓ Todo guardado».

G Bienvenida de miembro

- «Hola, Luka 👋», tarjeta **Tu ADN musical** y botón **Ofrecer huella / Face ID**.
- «Celébralo con esta»: una canción de tu Selección rápida que arranca su radio. Ir a Inicio.

H Tu cuenta (con sesión)

- **Cabecera**: avatar grande (cambiar), nombre (editar), correo con ✓ y tarjeta «Tu Liquid»: miembro desde · minutos escuchados · favoritas · estilo principal.
- **Sincronización**: «✓ Al día · hace 1 min» / «Sincronizando…» / «Sin conexión: se guarda al volver» · **Sincronizar ahora** · interruptor «Sincronizar también la escucha».
- **Seguridad**: Cambiar contraseña · Huella / Face ID (añadir, ver, quitar) · **Dispositivos conectados** («📱 Este teléfono · ahora», «💻 Chrome en Windows · hace 2 días», cada uno con Cerrar sesión; «Cerrar en todos los demás») · Actividad reciente.
- **Tus datos**: Descargar mis datos · Cambiar correo.
- **Cerrar sesión** con «borrar también lo guardado en este dispositivo» (para teléfonos prestados).
- **Zona roja · Borrar mi cuenta**: explica qué se borra, pide contraseña o passkey + código y da **7 días** para arrepentirse.

12 Textos, errores y estados

CÓDIGO DE ERROR	LO QUE VE LA PERSONA
`credenciales`	Correo o contraseña incorrectos.
`demasiados_intentos`	Demasiados intentos. Prueba en 5 min o recupera tu contraseña.
`codigo_incorrecto`	Código incorrecto · te quedan N intentos.
`codigo_caducado`	Ese código caducó. Te enviamos uno nuevo (revisa Spam).
`espera_reenvio`	Podrás pedir otro en 45 s.
`contrasena_debil`	Usa al menos 10 caracteres, con letras y números.
`contrasena_filtrada`	Esta contraseña apareció en una filtración conocida. Elige otra.
`correo_invalido`	Revisa el correo: parece que falta algo.
`sin_conexion`	No hay conexión. Puedes seguir sin cuenta y entrar luego.
`envio_no_disponible`	Estamos teniendo problemas para enviar correos. Prueba en unas horas.
`sesion_caducada`	Vuelve a entrar para seguir sincronizando. Tus datos de este dispositivo siguen aquí.
`robot`	No pudimos comprobar que eres tú. Toca para intentarlo de nuevo.

Estados que cubre toda la interfaz

- **Cargando:** botón con barra líquida y textos que cambian («Comprobando…», «Casi…»). Nunca un spinner mudo.
- **Sin conexión:** se ve lo último sincronizado; lo que necesita red aparece atenuado con el motivo.
- **Conflicto entre dos teléfonos:** se resuelve solo. Si no se pudiera: «Usar los dos (recomendado) / Solo este dispositivo».

- **Accesibilidad:**
  - Todo funciona con teclado.
  - Los errores se anuncian con `aria-live`.
  - Las 6 gotas son un solo campo para el lector de pantalla.
  - El foco se mueve al título de cada paso.
  - El contraste es AA en los 4 temas.
- **Ultraligero:** la misma hoja sin animaciones, sin collage, sin escena y sin imágenes.
- **Menos movimiento:** las gotas no tiemblan; cambian de color.

13 Correos que envía la app

CORREO	ASUNTO	CONTENIDO
Código	Tu código de Liquid Bullet: 482917	Logo, código enorme (`482 917`), «caduca en 10 min», «si no fuiste tú, ignóralo».
Bienvenida	Tu música ya está a salvo	3 trucos: Selección rápida, Lab y descargas offline. Enlace a la review.
Nuevo inicio de sesión	Nuevo inicio de sesión en tu cuenta	Dispositivo y hora. Botón «No fui yo: cerrar todo» (enlace de un solo uso, 24 h).
Contraseña o correo cambiado	Se cambió tu contraseña	Aviso + «¿No fuiste tú? Recupera tu cuenta».
Correo ya registrado	Alguien intentó crear una cuenta con tu correo	«Si fuiste tú, entra o recupera la contraseña». No revela nada en la app.
Borrado programado	Tu cuenta se borrará el 12 de noviembre	Botón «Cancelar el borrado».

Todos con versión en texto plano y HTML mínimo (sin imágenes remotas, el logo en línea). El asunto no tiene signos raros y es siempre el mismo por tipo: así reconocerlos en Spam es fácil.

14 Amenazas y defensas

AMENAZA	DEFENSA
Robo de la base D1	Contraseñas estiradas en el dispositivo + HMAC con pimienta secreta + PBKDF2 en el servidor. Tokens y códigos solo como hash.
Fuerza bruta de contraseñas	Turnstile, 5 fallos → espera creciente, límites por IP y por correo, aviso por correo de entradas nuevas.
Averiguar qué correos tienen cuenta	Respuestas idénticas en alta, entrar y recuperar; sal del dispositivo determinista; tiempos de respuesta iguales.
Abuso del envío de correos	Turnstile, topes por correo, IP y día, por debajo del límite de Gmail.
Robo del token de renovación	Rotación con detección de reutilización → se revoca la familia y se avisa.

Script malicioso en la web (XSS)	CSP estricta (ya existe, con hash de scripts); con Pages, cookie HttpOnly.
Leer datos de otro usuario	El Worker deriva la carpeta de R2 del pase firmado, nunca de un parámetro de la petición.
Archivos gigantes o basura	Máximo 2 MB por archivo, validación del esquema, gzip obligatorio.
Fuga de la contraseña de Gmail	Contraseña de aplicación (revocable sin tocar la cuenta) guardada como secreto del Worker; Gmail dedicado sin otros usos.
Pérdida de datos por conflicto	ETag + mezcla por reglas + marcas de borrado.
Arrepentimiento al borrar	7 días de gracia; luego el Cron borra D1 y R2 de forma definitiva.

Privacidad (texto nuevo para Ajustes)

«Sin cuenta, todo se guarda solo en este navegador. Si inicias sesión, tus favoritas, playlists, escucha y ajustes se guardan en el almacenamiento privado de Liquid Bullet en Cloudflare, comprimidos y separados por cuenta. Tu contraseña nunca se guarda ni se envía en claro. Puedes descargar o borrar todo cuando quieras. Sin anuncios ni analítica.»

15 Límites y costos

SERVICIO	GRATIS (VERIFICAR EN EL PANEL, PUEDEN CAMBIAR)	USO ESTIMADO CON 1.000 USUARIOS
Workers	100.000 peticiones al día	~15.000 al día
D1	5 GB en total · millones de filas leídas al día · 100.000 escritas al día	~1 MB · ~5.000 escrituras al día
R2	10 GB · 1 millón de escrituras y 10 millones de lecturas al mes	~0,2 GB · ~400.000 escrituras al mes
Turnstile · Rate Limiting · Cron	Incluidos	—
Gmail dedicado	~500 correos al día	~20–60 al día
Total	**0 USD**	

Si algún día se acerca un límite: para escrituras en R2, subir con menos frecuencia (cada 10 min); para correos, pasar al Plan B (sección 4). El tiempo de CPU del Worker queda bajo gracias al estiramiento en el dispositivo (sección 7.1).

16 Fases y criterios de aceptación

FASE	INCLUYE	LISTA PARA PUBLICAR CUANDO…
1 · Base	Worker, D1 (esquema del anexo A), bucket privado, Turnstile, envío por Gmail, alta con código, entrar, salir, pantallas A–D	Crear cuenta y entrar funcionan en móvil y escritorio; el código llega (bandeja o Spam) en < 1 min; los frenos se disparan en pruebas.
2 · Recuperar	Pantalla E, correos de aviso, detección de reutilización de tokens	Recuperar cierra las demás sesiones y avisa por correo.
3 · Sincronizar	Ids cortos, gzip, ETag, reglas de mezcla, pantalla F, estados en vivo	Dos dispositivos editando a la vez no pierden nada (test automático).
4 · Tu cuenta	Pantallas G–H: perfil, avatar, dispositivos, actividad, cambiar contraseña y correo, exportar, borrar con 7 días	Exportar devuelve todo; el borrado se cancela al entrar y se ejecuta a los 7 días.
5 · Passkeys	Registro y entrada con huella o Face ID	Entrar con passkey en Android, iPhone y escritorio.
6 · Esencia	Reloj derretido, ojos, gotas, medidor líquido, «Conoce Liquid», ADN, saludo con nombre	Las 4 caras de la app se ven bien; ultraligero y menos movimiento respetados.
7 · Cierre	Privacidad, novedades, tests Playwright de todos los flujos, revisión de seguridad	CI en verde; revisión de seguridad sin hallazgos altos.
Opcional	Mudanza a Cloudflare Pages + cookie HttpOnly	Redirección desde GitHub Pages sin romper enlaces.

17 Lo que necesito de ti

#	QUÉ	DETALLE
1	**Gmail dedicado** con verificación en dos pasos y **contraseña de aplicación**	Sección 4.1. Pásame la contraseña de aplicación por un canal privado.
2	**La base D1 nueva**	Nombre e id, y en qué cuenta de Cloudflare está.
3	**Un bucket R2 privado** en esa misma cuenta	P. ej. `liquid-cuentas`, sin acceso público.
4	**Un widget de Turnstile**	Clave del sitio (pública) y clave secreta (para el Worker), con el dominio `lukoffmon.github.io`.
5	**Publicar el Worker**	Yo escribo el código y la configuración; tú ejecutas `npx wrangler deploy` con tu sesión, o me das un token de API limitado a esa cuenta.

A Anexo: esquema SQL completo (D1)

```sql
-- migrations/0001_cuentas.sql · fechas en segundos Unix · ids y hashes en BLOB
CREATE TABLE usuarios (
  id            BLOB    PRIMARY KEY,              -- 16 bytes aleatorios
  correo        TEXT    NOT NULL,                 -- lower(trim(correo))
  confirmado    INTEGER NOT NULL DEFAULT 0,       -- fecha de confirmación o 0
  clave_hash    BLOB    NOT NULL,                 -- 32 bytes
  clave_sal     BLOB    NOT NULL,                 -- 16 bytes
  clave_ver     INTEGER NOT NULL DEFAULT 1,       -- versión del esquema de hash
  nombre        TEXT,
  avatar        TEXT,                             -- 'inicial:#ff7ad9' | 'emoji:🎧' | 'fondo:07' |
'icono:song-42'
  creado        INTEGER NOT NULL,
  actualizado   INTEGER NOT NULL,
  borrar_el     INTEGER                           -- borrado programado (7 días) o NULL
) STRICT;
CREATE UNIQUE INDEX usuarios_correo ON usuarios(correo);
CREATE INDEX usuarios_borrar ON usuarios(borrar_el) WHERE borrar_el IS NOT NULL;

CREATE TABLE sesiones (
  id            BLOB    PRIMARY KEY,              -- 16 bytes
  usuario       BLOB    NOT NULL REFERENCES usuarios(id) ON DELETE CASCADE,
  familia       BLOB    NOT NULL,                 -- detecta reutilización de tokens
  token_hash    BLOB    NOT NULL,                 -- SHA-256 del token de renovación
  dispositivo   TEXT,                             -- 'Android · Chrome'
  creada        INTEGER NOT NULL,
  vista         INTEGER NOT NULL,                 -- se actualiza como mucho 1 vez por hora
  caduca        INTEGER NOT NULL,
  revocada      INTEGER                           -- fecha o NULL
) STRICT;
CREATE UNIQUE INDEX sesiones_token ON sesiones(token_hash);
CREATE INDEX sesiones_usuario ON sesiones(usuario, caduca);
CREATE INDEX sesiones_familia ON sesiones(familia);

CREATE TABLE codigos (
  correo        TEXT    NOT NULL,
  motivo        TEXT    NOT NULL CHECK (motivo IN ('alta','recuperar','cambiar-correo','borrar')),
  codigo_hash   BLOB    NOT NULL,                 -- HMAC(pimienta, código|correo|motivo)
  datos         TEXT,                             -- alta pendiente: nombre, avatar, hash provisional
(JSON)
  intentos      INTEGER NOT NULL DEFAULT 0,
  caduca        INTEGER NOT NULL,
  PRIMARY KEY (correo, motivo)                    -- un código vivo por motivo
) STRICT, WITHOUT ROWID;
CREATE INDEX codigos_caduca ON codigos(caduca);

CREATE TABLE passkeys (
  id            BLOB    PRIMARY KEY,              -- id de credencial WebAuthn
  usuario       BLOB    NOT NULL REFERENCES usuarios(id) ON DELETE CASCADE,
  clave_publica BLOB    NOT NULL,
  contador      INTEGER NOT NULL DEFAULT 0,
  nombre        TEXT,                             -- 'iPhone de Luka'
  creada        INTEGER NOT NULL,
  usada         INTEGER
) STRICT, WITHOUT ROWID;
CREATE INDEX passkeys_usuario ON passkeys(usuario);

CREATE TABLE actividad (
  usuario       BLOB    NOT NULL REFERENCES usuarios(id) ON DELETE CASCADE,
  fecha         INTEGER NOT NULL,
  tipo          TEXT    NOT NULL,                 --
'entrada','clave','correo','dispositivo','passkey','borrado'
  dispositivo   TEXT
```

```
) STRICT;
CREATE INDEX actividad_usuario ON actividad(usuario, fecha DESC);

-- Cron diario
DELETE FROM codigos   WHERE caduca < unixepoch();
DELETE FROM sesiones  WHERE caduca < unixepoch() OR revocada < unixepoch() - 86400*30;
DELETE FROM actividad WHERE fecha  < unixepoch() - 86400*90;
-- + borrar usuarios con borrar_el < unixepoch() (y su carpeta de R2)
PRAGMA optimize;
```

B Anexo: configuración del Worker

```
# wrangler.toml (sin secretos)
name = "liquid-cuentas"
main = "src/index.js"
compatibility_date = "2026-11-01"

[[d1_databases]]
binding = "DB"
database_name = "<la base nueva>"
database_id = "<id>"

[[r2_buckets]]
binding = "DATOS"
bucket_name = "liquid-cuentas"

[[unsafe.bindings]]          # Rate Limiting
name = "LIMITE"
type = "ratelimit"
namespace_id = "1001"
simple = { limit = 20, period = 60 }

[triggers]
crons = ["17 4 * * *"]     # limpieza diaria (04:17 UTC)

[vars]
ORIGEN = "https://lukoffmon.github.io"
TURNSTILE_SITIO = "<clave pública>"
SMTP_USER = "liquidbullet.app@gmail.com"

# Secretos (wrangler secret put …): SMTP_PASS · PIMIENTA · FIRMA · TURNSTILE_SECRETO
```

C Anexo: formato de los datos (antes de gzip)

```
{
  "v": 1,
  "actualizado": 1793875200,
  "favoritas": { "b·c0bf5f": [1793875000, 1], "p·cae646": [1793870000, 0] },  // [fecha, 1 = está / 0 =
quitada]
  "playlists": [
    { "id": "m3k9x2", "nombre": "Lab · Trap Lunar + Seda", "emoji": "🧠", "color": "#7a5cff",
      "canciones": ["s·7d75e1", "b·0b1a2c"], "actualizado": 1793874000 },
    { "id": "q1w2e3", "borrada": 1793000000 }
  ],
  "sigue":   { "tame impala": [1793800000, 1] },
  "fijadas": { "sys:acido-lento": [1793800000, 1] },
  "ocultas": {},
  "saltos":  { "d·8e9855": 2 },
  "oida":    { "b·c0bf5f": 1793875100 },
  "plays":   { "<dispositivo>": { "b·c0bf5f": 14 } },
  "ajustes": { "tema": [1793000000, "chrome"], "fuente": [1793000000, "street"] }
}
// escucha-2026.json: { "2026-11-05": { "<dispositivo>": { "s": {"b·c0bf5f": 212}, "h": [..24], "g":
{...} } } }
```

Resumen en una línea

Cuentas opcionales con correo y contraseña, código desde tu Gmail dedicado (puede caer en Spam y la app lo dice), todo lo demás en Cloudflare a 0 USD, con una base D1 de ~1 KB por usuario, datos de música 8× más ligeros en R2 y una interfaz que se siente 100 % Liquid Bullet.